Company IT & Information Security Policy

Company: Acme Technologies Pvt. Ltd.

Document ID: IT-SEC-POL-001

Version: 2.0

Effective Date: January 1, 2026

Review Date: January 1, 2027

Policy Owner: Information Security Department

Approved By: Chief Information Security Officer (CISO)

1. Purpose

The purpose of this policy is to establish security standards for protecting company information, applications, infrastructure, customer data, and employee devices.

The policy defines requirements for authentication, password management, access control, data protection, network security, software development, cloud infrastructure, incident management, and backup procedures.

All employees, contractors, consultants, and third-party users who access company systems must comply with this policy.

2. Scope

This policy applies to:

- Company-owned computers and laptops.
- Virtual machines and servers.
- Cloud infrastructure hosted on Microsoft Azure.
- Corporate applications and APIs.
- Databases and file storage systems.
- Source-code repositories.
- Company networks and VPN connections.
- Customer information and business data.
- Third-party applications that process company information.

The policy applies to employees working from company offices, remote locations, and approved work-from-home environments.

3. Password Policy

All users must follow the company password requirements.

Passwords must:

- Contain at least 12 characters.
- Include uppercase and lowercase characters.
- Include at least one number.
- Include at least one special character.
- Not contain the employee's name or username.
- Not be reused across company applications.
- Not be shared with another person.

Passwords must be changed immediately if an employee believes that the password has been compromised.

Employees must not store company passwords in plain-text files, source-code repositories, emails, or chat messages.

The use of an approved enterprise password manager is recommended for storing credentials.

4. Multi-Factor Authentication

Multi-factor authentication (MFA) is mandatory for all privileged accounts and all applications containing sensitive company or customer information.

MFA must be enabled for:

- Microsoft Azure accounts.
- GitHub accounts.
- VPN access.
- Administrative applications.
- Production infrastructure.
- Database administration tools.

Authenticator applications or hardware security keys should be preferred over SMS-based authentication where supported.

Privileged accounts must not disable MFA without written approval from the Information Security Department.

5. Access Control

Access to company systems must follow the principle of least privilege.

Employees should receive only the permissions required to perform their assigned responsibilities.

Access requests must be approved by:

1. The employee's manager.
2. The application or system owner.
3. Information Security, when the requested access is privileged.

Production database access should normally be read-only unless write access is specifically required.

Administrative access must be reviewed at least once every six months.

When an employee leaves the organization, access to company systems must be revoked within four hours of the employee's termination notification.

6. Source Code Security

Company source code must be stored only in approved source-control repositories.

Developers must not commit:

- Passwords.
- API keys.
- Access tokens.
- Database connection strings containing credentials.
- Private certificates.
- Encryption keys.
- Customer confidential information.

Secrets must be stored using an approved secret-management solution such as Azure Key Vault.

Pull requests must undergo code review before being merged into the main branch.

Security-sensitive changes should receive additional review from a senior developer or security engineer.

7. GitHub Security

Company GitHub repositories must use organization-managed authentication and security controls.

Personal GitHub accounts must not be used to store company source code.

Fine-grained personal access tokens should be used instead of classic personal access tokens whenever a personal access token is required.

GitHub tokens must have the minimum permissions necessary for the intended operation.

Tokens must have an expiration date.

If a GitHub token is accidentally exposed, the token must be revoked immediately and a replacement token must be generated.

GitHub repositories containing production source code must enable branch protection rules.

8. Azure Cloud Security

All production Azure resources must be deployed into company-managed Azure subscriptions.

Azure resources must use Microsoft Entra ID authentication wherever possible.

Managed identities should be preferred over application secrets for Azure-to-Azure communication.

Production resources must not use developer personal accounts for authentication.

Azure role assignments must follow the principle of least privilege.

Resource access must be reviewed periodically.

Production secrets must be stored in Azure Key Vault.

Storage accounts containing confidential information must not allow anonymous public access.

9. Database Security

Production databases must not be directly exposed to the public internet unless explicitly approved by Information Security.

Database access should use encrypted connections.

Application accounts must have only the database permissions required by the application.

Database administrator credentials must not be stored in application source code.

Sensitive customer information must be encrypted at rest and protected during transmission.

Database backups must be encrypted.

Production database backups must be tested periodically to verify that they can be successfully restored.

10. API Security

All company APIs must use authenticated communication.

External APIs must use HTTPS.

API endpoints must validate authentication and authorization before processing protected operations.

APIs must validate incoming request data to prevent injection attacks and malformed requests.

Applications must implement appropriate rate limiting for externally accessible APIs.

Sensitive information must not be returned in API error messages.

API credentials must not be transmitted through URL query parameters.

API authentication tokens should be transmitted using the HTTP Authorization header.

11. Logging and Monitoring

Production applications must generate appropriate operational and security logs.

Logs should include:

- Authentication events.
- Authorization failures.
- Application errors.
- Administrative operations.
- Configuration changes.
- Security events.
- Critical system failures.

Logs must not contain:

- Passwords.
- API keys.
- Authentication tokens.
- Credit card numbers.
- Sensitive customer information.

Production logs should be retained according to the company's data-retention requirements.

Critical security alerts must be reviewed by the responsible operations or security team.

12. Incident Management

Employees must immediately report suspected security incidents to the Information Security Department.

Examples of security incidents include:

- Lost or stolen company devices.
- Compromised passwords.
- Exposed API keys.
- Unauthorized access.
- Malware infections.
- Suspicious emails.
- Data leakage.
- Unexpected production access.
- Customer information exposure.

The security team will classify incidents based on severity.

Critical security incidents must be escalated to the CISO immediately.

Incident investigation records must be maintained until the investigation and required corrective actions are completed.

13. Backup Policy

Critical production systems must be backed up according to the system's business-criticality classification.

Production databases must have automated backups.

Backup retention must be configured according to business and regulatory requirements.

Critical backups must be stored separately from the primary production environment.

Backup restoration tests must be performed at least once every six months.

A backup is considered successful only when the backup can be restored and the recovered data is verified.

14. Software Development Security

Developers must follow secure coding practices during application development.

Applications must be reviewed for:

- Authentication vulnerabilities.
- Authorization vulnerabilities.
- SQL injection.
- Cross-site scripting.
- Cross-site request forgery.
- Insecure deserialization.

- Sensitive information exposure.
- Dependency vulnerabilities.

Third-party NuGet packages must be reviewed for known security vulnerabilities.

Dependencies should be updated regularly.

Production applications must not use development or debug configurations.

15. Container and Kubernetes Security

Docker images used in production must be created from approved base images.

Containers must not run as root unless specifically required and approved.

Container images must be scanned for known vulnerabilities before deployment.

Kubernetes secrets must not be committed to source-control repositories.

Production Kubernetes deployments must define appropriate CPU and memory requests and limits.

Containers should use read-only file systems where practical.

Kubernetes service accounts should receive only the permissions required by their workloads.

16. Remote Access

Remote access to company systems must use the approved corporate VPN or zero-trust access solution.

Employees must not use public or unsecured networks for accessing sensitive production systems unless an approved secure connection is established.

Remote administrative access must use MFA.

Remote access sessions must be terminated when administrative work is completed.

17. Employee Responsibilities

Every employee is responsible for protecting company information.

Employees must:

- Lock their workstation when leaving it unattended.
- Protect passwords and authentication devices.
- Report suspicious activity.

- Follow company security procedures.
- Use approved software.
- Avoid storing confidential company information on personal devices.
- Complete mandatory security training.

Failure to comply with this policy may result in disciplinary action.

18. Data Classification

Company information is classified into four categories.

Public

Information that can be freely shared outside the company.

Examples:

- Public website content.
- Published marketing material.
- Public job advertisements.

Internal

Information intended for company employees.

Examples:

- Internal procedures.
- General operational documentation.
- Internal announcements.

Confidential

Information that could cause business impact if improperly disclosed.

Examples:

- Customer information.
- Internal financial information.
- Source code.
- Architecture documents.
- Internal contracts.

Restricted

Highly sensitive information requiring strict access controls.

Examples:

- Encryption keys.
- Production credentials.
- Security incident information.
- Highly sensitive customer data.
- Privileged administrative credentials.

19. Policy Exceptions

Any exception to this policy must be documented and approved by the Information Security Department.

Exception requests must include:

- Business justification.
- Systems affected.
- Security risks.
- Proposed mitigation.
- Requested duration.
- Responsible owner.

Temporary exceptions must have an expiration date.

Permanent exceptions require approval from the CISO.

20. Policy Review

This policy must be reviewed annually or whenever there is a significant change to company infrastructure, security requirements, regulatory obligations, or business operations.

The Information Security Department is responsible for maintaining this document.

End of Policy